

Animated Cursor Vulnerability - Proof of Concept - I

Module 16

Duration: 26:35

Video: <https://www.youtube.com/watch?v=I82Pgkv7Awc>

Course Coordinator - Dr Maninder Singh, Professor and Dean, Academic Affairs, Thapar University, Patiala

Subject Expert - Dr Maninder Singh, Professor and Dean, Academic Affairs, Thapar University, Patiala

Auto-generated YouTube transcript for personal study. Spoken wording belongs to the original lecture. Follow the video link above; this file is not an official CEC/SWAYAM publication.

0:00 in the previous lecture we have discussed about CV and scan CV as you know is common vulnerability and

0:09 exposure now as I told in the previous class that we are going to explore a real time vulnerability in Windows and

0:18 that vulnerability is called animated cursor vulnerability now what is this animated cursor

0:25 vulnerability as you might have seen there are n number of cursors which are available in in window like we have a

0:32 eye cursor when we are in a notepad we see this kind of a cursor and then we can have a r Glass cursor which is

0:40 animated which actually flows a sand from one part of a our glass into the another part and many a time you might have seen another cursor which is

0:49 somebody's riding a horse and that kind of a cursor the horse riding cursor so now as you can see the differentiation

0:57 between these cursors these are all animated and their size is different that means this animated cursor

1:07 is like horse animated cursor it has more size than the r Glass and which has more size than the I cursor now in order

1:16 to accommodate this Windows implemented the functionality of loading a cursor into a dll file which is called

1:24 user32.dll now this is d damic link Library which is available and this functionality is

1:33 available in that particular file now if you go to the Web Internet and search for animated cursor vulnerability

1:41 there's a precursor which is available on the web and this precursor says this vulnerability can be exploited by a

1:49 malicious web page and it results in remote code execution now there are two things which

1:57 we need to learn here one is what I mean by malicious web

2:04 page and second is remote code

2:12 execution now when I say malicious web page see whenever a security is implemented in an organization the

2:20 security is implemented mostly at a peripheries that means whatever traffic

2:27 is entering into my organization this tra is getting filtered out by a firewall on the periphery and this kind

2:36 of a firewall is called Network firewall that means whatever traffic is

2:44 coming from the outside world into man organization this traffic is going to get filtered at Network firewall

2:53 level but what happens if somebody from the inside of a network goes to a malicious website

3:00 I don't have any control over that because most of the organization are allowing HTTP and https traffic to flow

3:10 out of their organization so that the people can access web pages now the trouble which is going to

3:17 come here if a user from my network goes to a particular website and that website

3:26 itself hosts a malicious code then this particular guy may get

3:33 affected by that malicious code and this kind of an attack is called client side attack that means today we are going to

3:41 witness two things in unison one is client side attack and other is this

3:47 client side attack is going to exploit a vulnerability which is called animated cursor vulnerability in existing Windows

3:57 platform this vulnerability was discovered in 2007 it's a way back people may think that it's almost 8 year

4:05 back or 9 year back why we are going to talk about this vulnerability now

4:12 because still there are Legacy systems across the world which are available and those are hosting those Legacy operating

4:20 system which were vulnerable to this vulnerability and if anybody might not have passed his or her system against

4:29 this one vulnerability this vulnerability is going to cause a trouble of that system and it will allow

4:36 a remote code execution to happen now remote code execution means somebody remotely is able to run a code on my

4:44 machine which is very dangerous that means I'll be able to run a code on somebody else's machine without his KN

4:53 how and that code may be stealing of the information I may format the hard disk that that is what is called remote code

5:01 5 minutes, 1 second execution running any code on somebody else's machine without proper authorization and

5:08 authentication and that is the ultimate goal of an hacker that I should be able to run a remote code and that remote

5:16 code execution is one of the part of this animated cursor vulnerability let's do a step by step

5:24 execution of this particular vulnerability and try to understand where INRI cases of this and how we'll

5:32 be able to avoid this by patching the systems properly now in order to demonstrate

5:39 this we are going to create an isolated environment where we are going to experiment with three

5:47 systems one that system which is my host operating system which is Windows

5:54 10 second operating system is Linux and third operating system is Windows

6:02 XP now this Linux system is going to host a malicious web

6:11 page and this Windows XP system is going to access that malicious web

6:21 page and this malicious web page is going to offer a cursor which when gets

6:28 executed this cursor once gets executed is going to allow me to run a remote

6:35 code on that particular machine Let's do step by step execution

6:41 of this so for this what I have done I would require internet access so

6:48 that I can open up a page where a proof of concept is available and that proof of concept

6:56 says that this is an animation file animate DOI file which will trigger the

7:03 vulnerability when the folder containing it is open in Windows Explorer now I'm going to copy this

7:11 vulnerability this particular code and paste it into a text

7:18 file and this text file I have created in Linux so I'm just going to

7:26 open it I say Nano any. text I already pasted into

7:32 this any. text now you can see whatever was available on the internet the same thing is available here on my machine

7:40 because I just copy and paste it into a text file and I can check what kind of file

7:48 it is by file command so I say file any do text so it say it's a asky

7:56 text file now if I want to load this file on a remote machine first of all I'm going

8:02 to host this file in a web server and that web server we are going to use is called Apache Apache web

8:12 server now this particular text file cannot be loaded as an animated cursor because as soon as window operating

8:19 system sees this it says it's a simple text file it's not an animated cursor file so first thing which we are going

8:26 to do we are going to filter out this middle portion from the file which

8:34 starts with this 52 49 46 46 which is r i FF so this is a start of header for

8:42 animated text file so we are going to copy this whole stuff as a stream and paste it in a

8:49 binary file so that it becomes a animated cursor file so in order to do that we are going

8:56 to play with this file through a shell so let me open I'll say cat I'm using a

9:03 cat command to open any. text file so it shows me the content now next I want to filter out this content taking space as

9:13 a delimiter so I say cat any. txt and then I say cut minus D which is a d

9:21 limiter and I say space as a delimiter and I need field number three to 22

9:30 so why I say field number 3 to 22 you can count so this particular address 0000 0 so this is the first field then

9:39 we have a blank space which is the second field and field three starts from this 52 so this is field

9:45 three and then up to this 68 this is field number 23 so we are going to take from F3 to 23

9:55 and you see what it gives me it gives me the center part of a file now I have to get rid of these

10:03 spaces also and apart from these spaces I'm going to get rid of sln at the end so I'm going to write this I say cut

10:12 minus D F3 and then pipe this particular output to a stream editor and in the Stream editor I say

10:21 substitute space with non space globally now as soon as I do this you see I have got a stream of

10:30 hexadecimal characters but still there is sln which is available in this so I'll get rid of that also by using a

10:37 translation so I output this particular output into a translator I said

10:43 TR and I said delimiter as sln so sln is a delimiter now you see I

10:52 got a stream of characters so I'm going to copy this whole stream

10:59 start from 52 I'll copy until this 43 right click and say copy I copied the

11:07 stream now I am going to paste this whole string into a binary file so that it becomes a animated cursor file so in

11:16 order to in order that to happen I'm going to say Echo and I put any character let's say m

11:25 into a file called demo do Ani so it created a file called

11:33 demo. so if I say file demo. it says a asky text file because

11:41 still it does not have that riff header in place so now we are going to open this file as hexedit minus B

11:53 demo. now as you can see it has only two character one is M and followed by enter so I'm going to fill this whole file by

12:02 zeros and these zeros will make a space for my buffer which I copied just now so good enough enough a space at

12:10 this point of time so we'll paste that stuff which we have copied here so as you can see and rest of the zeros I'm

12:18 going to delete so all other stuff is going to get deleted from this file now I have perfectly the same kind of file

12:26 which was available on the internet as proof of concept with me now it starts

12:32 from 52 49 46 46 which is RF header and it goes up to 43 43 43 43 which is

12:41 equalent to c c c c as in the S text so I'll say contr x save this file demo in

12:50 this folder and now check it with file command I say file demo. Ani now let say

12:58 it is a riff little andian data which is animated cursor that means now my machine recognizes this particular file

13:05 as a Ani file now I am going to tell this file to get

13:12 uploaded on a web through a body cursor command and then this will be accessible

13:19 to the outside world through a website URL now what is the next step to be done

13:28 so we are going to create create a page which is a crafted page and that page will have this

13:35 content so I open up exp. HTML and I say here HTML body

13:44 style cursor URL is demo. and I'm just typing animated

13:52 cursor demo and then close the body and finally close the HTML part so this has created a exp. HTML

14:01 14 minutes, 1 second file in my current folder now I'm going to expose this with the help of a

14:09 browser so in order to know whether a server is running on my system or not a web server so I simply say a command net

14:19 startat netstat minus a n More now here you can see it says the

14:28 TCP protocol call port number 80 and this port is in listen state that means my Apache web server is running on this

14:36 machine and it can offer web pages to the clients through a

14:43 URL and this .html page is now available to the outside

14:49 world now let's go to the Windows machine and try to access this particular web page so I'm going to

14:58 open Internet Explorer and type uh IP address of my

15:05 Apache web server so I say 192.168.1.172 16872 1228 followed by exp. HTML now

15:16 once I do this you see it simply says animated cursor demo but nothing happens on this machine as such that means my

15:24 window accepted this as an animated cursor and it might have try to load it but this output is not available here as

15:32 part of a Internet Explorer so next thing what I am going to do I'm going to attach this particular

15:41 file in order to understand what is happening inside the memory I'm going to open up olbg which is a debugger and

15:50 this debugger is going to debug my Internet Explorer

15:57 program so so I say attach and search for I explore here I

16:04 explore is a EX file which is actually Internet Explorer on my system so I attach

16:14 this and I when I attach this function you see it is going to show me some things on the screen let's first of all

16:22 understand what is an output of this so I'm going to run this program now the first pan Which you you're seeing here

16:30 this pan is the memory area so the first part is The Logical

16:38 addresses second part is the op code and third part is the assembly

16:46 code and this program is getting debugs so I'm going to restart this

16:55 program and I make this program run so it opens up uh Explorer now I say open the window

17:04 HTTP colon 192.168 exp.

17:10 HTML now as you can see what has happened you see this it says access

17:18 violation when executing 42 42 42 42 that means my EIP which is my instruction

17:27 poter register as when I was explaining I was trying to tell you that this EIP is most important

17:35 part because it is it contains the address of next instruction which is going to get executed now at this point

17:42 of time what has happened this EIP is having a string 42 42 42 42 that means

17:50 this is a part of a buffer which I had sent to this particular program now EIP

17:58 is pointing to this this particular address 424242 which is not exactly as part of this program so that's why I'm I'm

18:07 getting a access violation so now because we got a buffer

18:15 got overflow and this is this has overwritten the EIP now we are going to play with this EIP and put some address

18:25 here and this particular address is going to catch my buffer and within a buffer I

18:32 can implant a malicious code and by virtue of this malicious code I'll be able to run a remote code on the remote

18:42 machine now how I'm going to do that let's first of all understand the structure of an ani file

18:51 so I'm going to open this I'll say hexedit demo.

19:00 right you see this is a structure now what my point is that I want to jump from this

19:08 90 instruction and I want to go down here at 40 through 43 43 and after that

19:16 I can embed a malicious code into this particular file because file Size Doesn't Matter here I can have a small

19:24 file with a limited kind of Animation I can have a bigger file with more animation and that's why it is called

19:33 animated cursor file now if I'm going to let's say overwrite a part of this file let's say

19:41 5249 I overwrite it with some instruction then my window is not going to recognize this as a animated cursor

19:49 file so in order that this file gets recognized as a animated cursor file I

19:57 will not be able to touch these four bytes next comes these two bytes from these two bytes I need to jump to this

20:06 location and if you count the number of bytes these bytes are much more than 127 which is a limit for a short jump so the

20:16 short jump can be at the maximum 127 bytes so I can jump from one location of

20:23 memory to another location of memory by having 127 bytes at has a maximum jump

20:30 so I am going to do here I'll say EB that jump from this part up to 16 bytes so 16 bytes are

20:39 going to take me to this 0 0 0 0 and luckily I'll be able to overwrite this

20:46 part also so I'll say EB 77 which will take me to this particular

20:54 address here that means I I have created two

20:59 jumps one jump of 21 bytes from EB 90

21:06 that is eb16 to e77 so this is a small island so I created a small island and jump from one memory location to this

21:16 island and from this island I'll jump back to my buffer and within a buffer I'll have a malicious code I hope you now understand that what

21:24 I trying to do here so now first of all let's safeguard this and make these bytes as no

21:32 operations 90 90 90 90 so 90 90 90 is a

21:36 no operation and here at 42 42 42 I need

21:43 a address which is going to point to my buffer so this address we'll find out in the memory so first of all let's save

21:52 this file and I'm going to go back to my Windows machine and in the Windows machine I'm

22:00 going to restart this debugger so I say restart now I'll open up this

22:11 file in Explorer so I give the address I say

22:18 192 do 16872 128. exp. HTML

22:30 so now you see again it crashes and my memory area is 52 52 52 and this 52 5 42

22:40 42 42 sorry not 52 this 42 42 42 42 this is pointing to a memory location which
22:48 is over written now I need to find out a register here which is going to point to my
Rift buffer so that I can jump back
22:56 to this buffer so if we go here to ESI buffer and say follow in Dump so I see in
23:04 memory there are certain address which are written but if I click on this addresses
and again right click and say follow
23:12 this double word in dump you see I got a buffer available in memory at this
23:21 particular address and now I'll be able to jump to this address through this EIP
manipulation
23:29 so now we need to do one thing here we first of all need to find address of ESI jump
double word in the
23:39 memory now where I'm going to find it so for that we need to learn one concept
and that concept is apart from my
23:48 program let's say my program name is ABC apart from this program in memory
23:56 there are many other dll file files which are sitting in memory like user 32 shell
24:05 32 Kel 32 etc etc so these are the file which
24:11 are available in the memory and if these files are available to my program in
memory so what may happen my program can
24:21 access the memory location of user 32 of shell 32 or of Kernel 32 if is available
24:29 if the A's violation is not permitted in that case now if we see ABC if we see ABC
24:37 here so ABC is going to access user 32 and by virtue of which I'll be able
24:43 to find the address of jump ESP instruction now if we go back to
24:53 original program we saw that in the memory there is an address which is pointed
by
25:01 25 minutes, 1 second ESI and once we found this address we are going to overwrite
over EIP with that
25:08 address so up to this we have seen in the next class we are going to explore further
and find out this address within
25:16 a memory space and this memory space would be of user32.dll once we we found
25:23 that address we are going to embed our buffer with this new address and with this
new address we'll be able
25:31 to jump to that location and execute an arbitrary code on the remote
25:37 machine so within this lecture I had explained you a animated cursor vulnerability
this
25:45 vulnerability is going to expose many of the Windows system Windows XP Windows
200000 and even Windows
25:54 Vista and this vulnerability gets executed whenever a user visits a
26:01 26 minutes, 1 second malicious web page and that malicious web page is hosted on
a server and This Server

26:10 contains this animated proof of concept and we are going to explore it further that how we'll be able to run a

26:18 remote code execution on this particular site so with a reference to this you can

26:26 go back home and study more about CLI side attacks and buffer overflow so meet

26:32 you in the next class thank you